GRC 10ALYTICS JUNE 2026 COHORT

ASSIGNMENT

ISO/IEC 27001 COMPLIANCE FRAMEWORK: NOVACARE HEALTH SERVICES

NAME: MOYINOLUWA AREGBESOLA

INSTRUCTOR: VICTORIA OLUYORI

SUBMITTED: MONDAY AUGUST 17, 2026

NovaCare Health Services is a developing healthcare company with three outpatient facilities in Ghana. It uses both on premises and cloud based technologies to handle patient records, appointment scheduling, payroll, supplier data, and financial transactions. NovaCare's main business activities include healthcare delivery, patient administration, patient record management, finance and billing, appointment scheduling, supplier management, payroll and IT operations.

The management has chosen to put in place an Information Security Management System (ISMS) that is in line with ISO/IEC 27001 to improve information security governance, control risks, and get ready for certification. There are a number of flaws in the current state of affairs, such as the lack of a clear ISMS scope, out-of-date or incomplete security policies, inconsistent risk assessments, no formal information asset inventory, no documented Statement of Applicability (SoA), and inconsistent security awareness and supplier security evaluation. In order to fix these gaps and get closer to ISO/IEC 27001 certification preparedness, what this report does is propose a workable strategy.

Cloud and on premises systems are combined in NovaCare's information environment. Therefore, the ISMS should support dependable clinic operations while safeguarding their patients' and business information's confidentiality of information by preventing unauthorised access or disclosure, integrity of information by preventing unauthorised alteration or destruction, and availability of information and systems so that healthcare and business services can continue operating.

The key stakeholders of NovaCare are;

• Executive management: they provide guidance, resources, oversight and risk acceptance.

• Clinical staff members: they generate, retrieve, and use their patient and treatment records.

• Finance and administration: they manage supplier and administrative records, payroll and financial transactions.

• IT/Operations: they oversee infrastructure, access, cloud services, EHR and technical controls.

• Suppliers: they provide cloud services, technology and other services, and they may process or access organizational data.
• Customers and patients rely on NovaCare to provide dependable services and keep private information secure.

Information Security Management System (ISMS) Scope Statement

Proposed scope

The NovaCare Health Services ISMS will include all the staff, standard processes, information, data, infrastructure, and technology used in all three of Ghana's outpatient clinics to provide and support medical care as well as business operations. The scope will include clinical services, patient records, appointment scheduling, finance and invoicing, payroll, supplier data, IT operations, Electronic Health record (EHR), cloud services, on-premises systems, networks, endpoints and supplementary information processing tasks.

From a governance and supplier risk point of view, third party cloud, medical, and technology vendors are included. Supplier security requirements, contracts, assurance information, access arrangements, and monitoring fall within NovaCare's control even though they might not directly manage a supplier's environment.

The operating scope does not include personal devices, systems, or services that are not connected to or authorized by NovaCare's normal business operations. Any exclusion has to be supported by documentation and cannot be used to dodge addressing a significant risk to information security.

Proposed ISMS objectives

• Prevent unauthorized access, loss, alteration and disclosure of NovaCare Health patients, employee, supplier and financial data.

• Create a consistent, risk based information security management procedure for each of the three clinics.

• Increase employee and appropriate third party security awareness and accountability.

• Improve cloud and supplier security governance.

• Keep the documents, proof, and efficient controls required for internal assessment and future certification.

ISO/IEC 27001 Gap Analysis

First, the scope of NovaCare's ISMS is currently unclear. The organization cannot clearly show which locations, systems, procedures, data, and interactions with third parties are protected by its information security management system without an approved scope.

Secondly, the organization's information security guidelines are out-of-date or not sufficient. Employees may not have clear and up-to-date requirements about their information security duties and this results in a governance gap.

Thirdly, NovaCare's risk assessments are uneven and they don't have a systematic information asset inventory. Because of this, the organization might not fully understand what systems and data need to be protected, what threats they could face, or who is in charge of handling those risks.

Another major gap is the lack of a Statement of Applicability and properly defined and documented security procedures. Without this information, NovaCare is unable to provide a clear explanation of how the risks it has identified are being managed by the proper controls.

Also, the organization's supplier security management and security awareness are weak points. Supplier security standards are assessed inconsistently, and security awareness training is not often done. The confidentiality, integrity, and accessibility of NovaCare's data can be impacted by both the employees and outside parties which adds to the risk.

The areas with the biggest gaps which are governance, risk management, asset management, access control, supplier security, employee awareness and control documentation should be given priority.

Annex A Control Recommendations

1. **Information Security Policies**
   Since NovaCare's current rules are either out-of-date or insufficient, information security procedures should be put into place. To ensure that employees are aware of the security requirements that apply to their job, the organization should create, approve, communicate, and evaluate its information security policies on a regular basis.

2. **Information Security Roles and Responsibilities**
   To resolve confusing accountability, information security roles and responsibilities should be defined. Information assets, security controls, incident management, risk management, and ISMS management should all fall under NovaCare's control.

3. **Inventory of Information and Associated Assets**
   Because NovaCare does not yet have a formal asset inventory, the Inventory of Information and Associated Assets is very crucial. The organization should assign the proper owners for its critical data, systems, devices, applications, and services. This will make it possible to associate controls and risks with particular assets.

4. **Classification of Information**
   Sensitive information should be carefully protected through the use of classification. Information on patients, finances, employees, and suppliers should be categorized based on how sensitive it is, and it should be handled and protected appropriately.

5. **Access Control**
   The risk of unauthorized access should be addressed by access control. In order to guarantee that employees only have the access necessary for their duties, access should be determined by minimum privilege and valid business requirement.

6. **Information Security in Supplier Relationships and Information Security Within Supplier Agreements**
   NovaCare depends on outside suppliers, supplier agreements must be put into place. Supplier agreements should include suitable security, confidentiality, access, and incident reporting requirements after supplier security risks have been evaluated.

7. **Information Security for Use of Cloud Services**
   Because NovaCare uses cloud-based solutions, information security for use of cloud services should also be implemented. The purchase, use, administration, and supervision of cloud services should all be subject to security standards.

8. **Information Security Awareness, Education and Training**
   The danger of employee mistakes, phishing, and improper information handling should be addressed through information security awareness, education, and training. During onboarding and on a regular basis after onboarding employees, NovaCare should keep providing security awareness training.

9. **Privileged Access Rights and Secure Authentication**
   By limiting administrative access and implementing strong authentication procedures, privileged access rights and secure authentication can lower the likelihood of hacked or compromised accounts.

10. **Management of Technical Vulnerabilities and Information Backup**
    Vulnerabilities should be found and fixed with the proper patching and repair using the management of technical vulnerabilities approach. Information backups should be kept up to date and routinely checked in order to safeguard vital patient and company data against ransomware and data loss.

11. **Logging and Monitoring Activities**
    In addition to helping NovaCare identify and look into suspicious activity, logging and monitoring activities should give visibility into significant system activity. In order to report, evaluate, respond to, and use security incidents as opportunities for improvement, it is also necessary to set up appropriate incident management systems.

Plan-Do-Check-Act (PDCA) Improvement Plan for ISMS

Plan

The ISMS scope, organizational context, interested parties, security goals, roles, and responsibilities should all be defined and approved by NovaCare first. After that, the company should finish its information asset inventory and create a formal risk register and standardized risk assessment process. This phase will serve as the basis for determining which risks need to be addressed.

Do

NovaCare needs to choose the appropriate Annex A controls, update its information security policies, and record the Statement of Applicability. It is necessary to assign control owners and preserve implementation proof. In addition to strengthening supplier and cloud security requirements, NovaCare should conduct security awareness training throughout this phase.

Check

NovaCare should use security metrics, control testing, access reviews, vulnerability assessments, and other suitable monitoring activities to keep an eye on the controls' efficiency once they are in place. After that, an internal audit should determine whether controls are working as planned and whether the ISMS complies with its requirements.

Act

Corrective action should be taken by NovaCare to address audit findings, events, and any identified lapses. Management should maintain the risk record, assess ISMS performance, and further improve controls as needed. Before applying for external certification, the organization should carry out a final readiness assessment to find out whether significant gaps have been filled.

All of these PDCA approach should be a continuous cycle instead of being a one-time endeavor. As risks, technology, and business needs evolve, they will enable NovaCare to continuously enhance its information security management system.

NovaCare's primary information security concern includes the lack of a structured management system linking governance, risks, information assets, controls, responsibilities, and continuous improvement. The three clinics, information, systems, personnel, procedures, and relevant third-party interactions of NovaCare are all clearly defined by the proposed ISMS scope. The organization's primary shortcomings in governance, risk management, asset management, documentation, awareness, and supplier security are identified by the gap analysis.

The risks particularly related to unauthorized access, sensitive information, technical vulnerabilities, suppliers, human error, and operational interruption are addressed by the suggested Annex A controls, which offer a risk-based starting point.
By putting the suggested controls into practice, recording the Statement of Applicability, carrying out internal audits and management reviews, and adhering to the PDCA improvement cycle, NovaCare can create a more reliable and consistent information security management system and slowly make progress towards ISO/IEC 27001 certification readiness.